

Introduction and Security Trends



Chapter 1

Objectives

- **List and discuss recent trends in computer security**
- **Describe simple steps to take to minimize the possibility of an attack on a system**
- **Describe various types of threats that exist for computers and networks**
- **Discuss recent computer crimes that have been committed**

Key Terms

- Critical infrastructures
- Elite hackers
- Hacker
- Hacking
- Hacktivist
- Highly structured threat
- Information warfare
- Ping sweep
- Port scan
- Script kiddies
- Structured threat
- Unstructured threat

The Security Problem

- **Fifty years ago, computers and data were uncommon.**
- **Computer hardware was a high-value item and security was mainly a physical issue.**
- **Now, personal computers are ubiquitous and portable, making them much more difficult to secure physically.**
- **Computers are often connected to the Internet.**
- **The value of the data on computers often exceeds the value of the equipment.**

The Security Problem *(continued)*

- **Electronic crime can take a number of different forms, but the ones we will examine here fall into two basic categories:**
 1. **Crimes in which the computer was the target**
 2. **Incidents in which a computer was used to perpetrate the act**
- **Virus activity also existed prior to 1988, having started in the early 1980s.**

Sample of Security Incidents

- **The Morris Worm (November 1988)**
- **Citibank and Vladimir Levin (June–October 1994)**
- **Kevin Mitnick (February 1995)**
- **Omega Engineering and Timothy Lloyd (July 1996)**
- **Worcester Airport and “Jester” (March 1997)**
- **Solar Sunrise (February 1998)**
- **The Melissa Virus (March 1999)**
- **The Love Letter Virus (May 2000)**
- **The Code Red Worm (2001)**
- **Adil Yahya Zakaria Shakour (August 2001–May 2002)**
- **The Slammer Worm (2003)**
- **U.S. Electric Power Grid (1997–2009)**
- **Conficker (2008–2009)**
- **Fiber Cable Cut (2009)**

Threats to Security

- **Internal vs. external**
- **Elite hackers vs. script kiddies**
- **Unstructured threats to highly structured threats**

Viruses and Worms

- **It is important to draw a distinction between the writers of malware and those who release it.**
- **Viruses *have no* useful purpose.**
- **Viruses and worms are the most common problem that an organization faces.**
- **Antivirus software and system patching can eliminate the largest portion of this threat.**
- **Viruses and worms generally are non-discriminating threats.**
- **Viruses are easily detected and generally not the tool of choice for highly structured attacks.**

Malware

- **Viruses and worms are just two types of *malware* threats.**
- **The term “malware” comes from “malicious software.”**
- **Malware is software that has a nefarious purpose, designed to cause problems to an individual (for example, identity theft) or your system.**

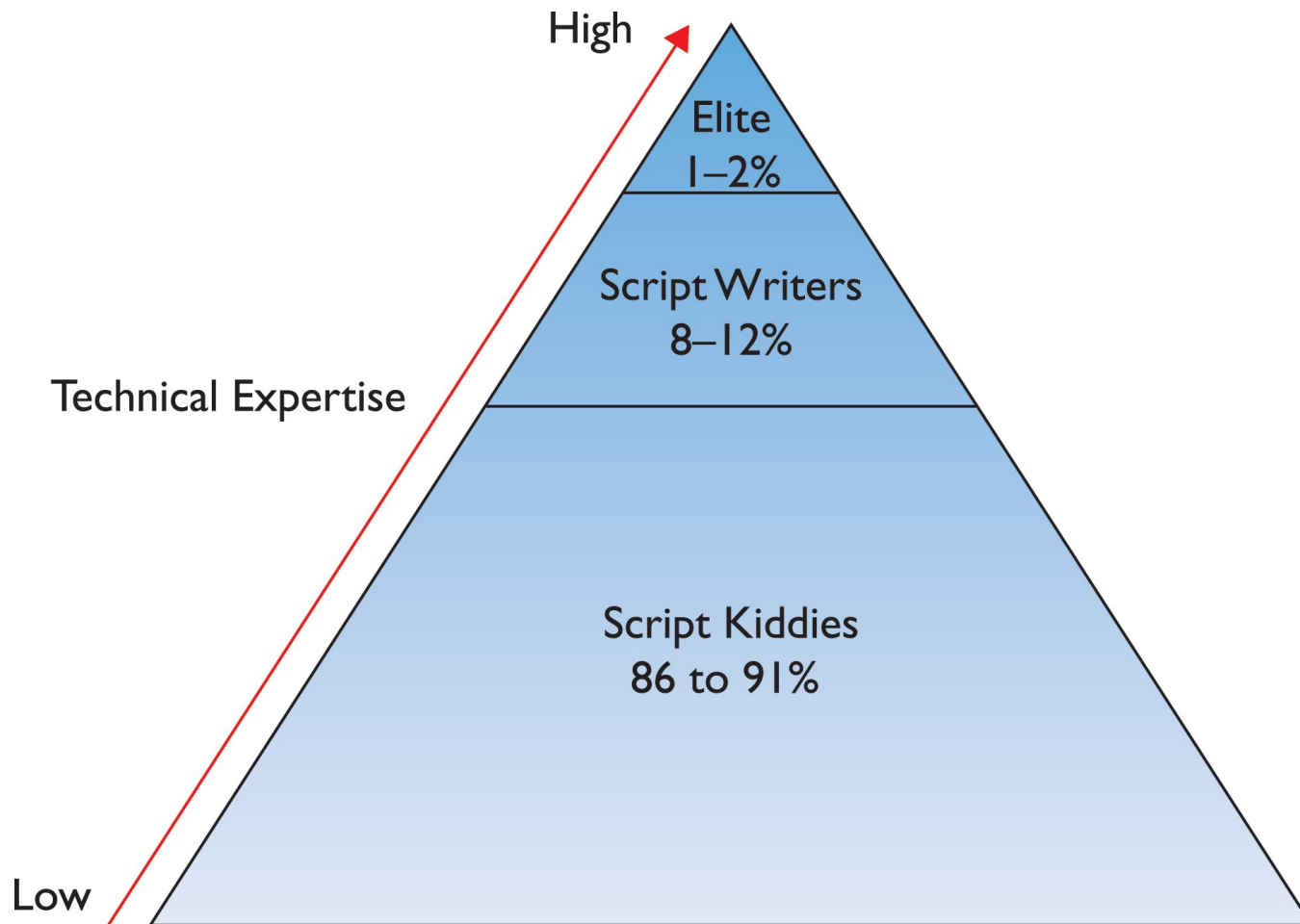
Intruders

- **Hacking** is the act of deliberately accessing computer systems and networks without authorization.
- **Hackers** are individuals who conduct this activity.
- **Hacking** is not what Hollywood would have you believe.
- **Unstructured threats** are conducted over short periods of time (lasting at most a few months), do not involve a large number of individuals, have little financial backing, and are accomplished by insiders or outsiders who do not seek collusion with insiders.

Types of Intruders

- **Script kiddies** are individuals who do not have the technical expertise to develop scripts or discover new vulnerabilities. They have enough understanding of computer systems to download and run scripts that others have developed.
- **Script writers** are those people who are capable of writing scripts to exploit known vulnerabilities. These individuals are much more technically competent than script kiddies and account for an estimated 8 to 12 percent of malicious Internet activity.
- **Elite hackers** are those highly technical individuals, who not only have the ability to write scripts that exploit vulnerabilities but also are capable of discovering new vulnerabilities. This group is the smallest of the lot, however, and is responsible for, at most, only 1 to 2 percent of intrusive activity.

Principles of Computer Security: CompTIA Security+® and Beyond, Second Edition



Insiders

- **Insiders are more dangerous in many respects than outside intruders because they have the access and knowledge necessary to cause immediate damage to an organization.**
- **Attacks by insiders are often the result of employees who have become disgruntled with their organization and are looking for ways to disrupt operations.**
- **It is also possible that an “attack” by an insider may be an accident and not intended as an attack at all.**

Criminal Organizations

- **As financial transactions over the Internet increased, criminal organizations followed the money.**
- **Fraud, extortion, theft, embezzlement, and forgery all take place in an electronic environment.**
- ***A structured threat* is characterized by a greater amount of planning, longer time to conduct the attack, and more financial backing than in an unstructured attack.**

Terrorists and Information Warfare

- **Computer systems are important assets that nations depend upon. As such, they are now targets of unfriendly foreign powers.**
- ***Information warfare* is the warfare conducted against the information and information processing equipment used by an adversary.**
- **Information warfare is a highly structured threat.**

Critical Infrastructures

- **During warfare, nations may choose targets other than the opposing army.**
- ***Critical infrastructures* are those whose loss or impairment would have severe repercussions on society. These include water, electricity, oil and gas refineries, banking, and telecommunications.**
- **Terrorists may also target these critical infrastructures.**

Security Trends

- **The trend has been away from large mainframes to smaller personal computers.**
- **As the level of sophistication of attacks has increased, the level of knowledge necessary to exploit vulnerabilities has decreased.**

Avenues of Attack

- **There are two general reasons a particular system is attacked:**
 - **It is specifically targeted.**
 - **It is a target of opportunity.**
- **Equipment may be targeted because of the organization it belongs to or for political reasons.**
- **These attacks are decided before the software or equipment of the target is known.**
- **A *hacktivist* is a hacker who uses their skills for political purposes.**

Avenues of Attack *(continued)*

- **Targets of opportunity** – attacks are conducted against a site that has software vulnerable to a specific exploit.
In these instances, the attackers are not targeting the organization, instead they are targeting a vulnerable device that happens to belong to the organization.
- **Targeted attacks** – specifically targeted attacks generally are more difficult and take more time than targets of opportunity.

The Steps in an Attack

Step		
1 Profiling	Gather information on the target organization	Check the SEC EDGAR web site (www.sec.gov/edgar.shtml), whois look up, google
2	Determine systems available	Ping sweep with nmap or superscan
3 Finger printing	Determine the OS and open ports	Nmap or superscan, banner grab
4	Discover applicable exploits	Search web sites for vulnerabilities and exploits that exist for the OSes and services discovered
5	Execute exploit	Systematically execute exploits

Minimizing Possible Avenues of Attack

System hardening	Involves reducing the services that are running on the system
Patching	Ensures that your operating system and applications are up-to-date
Limiting information	Makes it more difficult for an attacker to develop the attack by limiting the information available about your organization

Backdoor or Trapdoor

- ❑ secret entry point into a program
- ❑ allows those who know access bypassing usual security procedures
- ❑ have been commonly used by developers
- ❑ a threat when left in production programs allowing exploited by attackers
- ❑ very hard to block in O/S
- ❑ requires good s/w development & update

Logic Bomb

- ❑ one of oldest types of malicious software
- ❑ code embedded in legitimate program
- ❑ activated when specified conditions met
 - eg presence/absence of some file
 - particular date/time
 - particular user
- ❑ when triggered typically damage system
 - modify/delete files/disks, halt machine, etc

Trojan Horse

- ❑ program with hidden side-effects
- ❑ which is usually superficially attractive
 - eg game, s/w upgrade etc
- ❑ when run performs some additional tasks
 - allows attacker to indirectly gain access they do not have directly
- ❑ often used to propagate a virus/worm or install a backdoor
- ❑ or simply to destroy data



Mobile Code

- program/script/macro that runs unchanged
 - on heterogeneous collection of platforms
 - on large homogeneous collection (Windows)
- transmitted from remote system to local system & then executed on local system
- often to inject virus, worm, or Trojan horse
- or to perform own exploits
 - unauthorized data access, root compromise

Viruses

- ❑ piece of software that infects programs
 - modifying them to include a copy of the virus
 - so it executes secretly when host program is run
- ❑ specific to operating system and hardware
 - taking advantage of their details and weaknesses
- ❑ a typical virus goes through phases of:
 - dormant
 - propagation
 - triggering
 - execution



Virus Structure

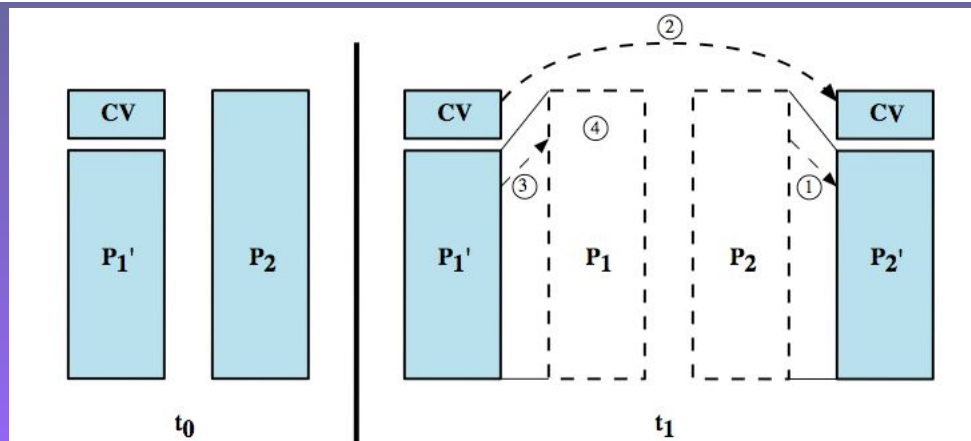
- components:
 - infection mechanism - enables replication
 - trigger - event that makes payload activate
 - payload - what it does, malicious or benign
- prepended / postpende / embedded
- when infected program invoked, executes virus code then original program code
- can block initial infection (difficult)
- or propagation (with access controls)

Virus Structure

```
program V :=  
{goto main;  
 1234567;  
  
  subroutine infect-executable :=  
    {loop:  
      file := get-random-executable-file;  
      if (first-line-of-file = 1234567)  
        then goto loop  
        else prepend V to file; }  
  
  subroutine do-damage :=  
    {whatever damage is to be done}  
  
  subroutine trigger-pulled :=  
    {return true if some condition holds}  
  
main:  main-program :=  
      {infect-executable;  
      if trigger-pulled then do-damage;  
      goto next;}  
  
next:  
  
}
```

Compression Virus

```
program CV :=  
{goto main;  
 01234567;  
  
  subroutine infect-executable :=  
    {loop:  
      file := get-random-executable-file;  
      if (first-line-of-file = 01234567) then goto loop;  
      (1)   compress file;  
      (2)   prepend CV to file;  
    }  
  
main:  main-program :=  
      {if ask-permission then infect-executable;  
      (3)   uncompress rest-of-file;  
      (4)   run uncompressed file;}  
}
```



Virus Classification

- ❑ boot sector
- ❑ file infector
- ❑ macro virus
- ❑ encrypted virus
- ❑ stealth virus
- ❑ polymorphic virus
- ❑ metamorphic virus



Macro Virus

- ❑ became very common in mid-1990s since
 - platform independent
 - infect documents
 - easily spread
- ❑ exploit macro capability of office apps
 - executable program embedded in office doc
 - often a form of Basic
- ❑ more recent releases include protection
- ❑ recognized by many anti-virus programs

E-Mail Viruses

- more recent development
 - e.g. Melissa
 - exploits MS Word macro in attached doc
 - if attachment opened, macro activates
 - sends email to all on users address list
 - and does local damage
 - then saw versions triggered reading email
 - hence much faster propagation
- 

Worms

- ❑ replicating program that propagates over net
 - using email, remote exec, remote login
- ❑ has phases like a virus:
 - dormant, propagation, triggering, execution
 - propagation phase: searches for other systems, connects to it, copies self to it and runs
- ❑ may disguise itself as a system process
- ❑ concept seen in Brunner's "Shockwave Rider"
- ❑ implemented by Xerox Palo Alto labs in 1980's

Morris Worm

- ❑ one of best know worms
- ❑ released by Robert Morris in 1988
- ❑ various attacks on UNIX systems
 - cracking password file to use login/password to logon to other systems
 - exploiting a bug in the finger protocol
 - exploiting a bug in sendmail
- ❑ if succeed have remote shell access
 - sent bootstrap program to copy worm over